verifier in the request. The AS will check that the SHA-256 hash of the code verifier matches the code challenge that it received in the authorization request. If they differ, then it rejects the request. PKCE is very secure, because even if an attacker intercepts both the redirect to the AS and the redirect back with the authorization code, they are not able to use the code because they cannot compute the correct code verifier. Many OAuth2 client libraries will automatically compute PKCE code verifiers and challenges for you, and it significantly improves the security of the authorization code grant so you should always use it when possible. Authorization servers that don't support PKCE will ignore the additional query parameters, because this is required by the OAuth2 standard.

7.3.3 Refresh tokens

In addition to an access token, the AS may also issue the client with a *refresh token* at the same time. The refresh token is returned as another field in the JSON response from the token endpoint, as in the following example:

```
$ curl -d 'grant_type=password
[CA]&scope=read_messages+post_message
[CA]&username=demo&password=changeit'
[CA] -u test:password
[CA]https://as.example.com:8443/oauth2/access_token
{
  "access_token":"B9KbdZYwajmgVxr65SzL-z2Dt-4",
  "refresh_token":"sBac5bgCLCjWmtjQ8Weji2mCrbI",    #A
  "scope":"post_message read_messages",
  "token_type":"Bearer","expires_in":3599}
```